

Laboratório SOC Analyst N1 — Investigação de Malware Detectado por Antivírus

Cenário

Sou analista SOC Nível 1 da empresa fictícia **VisionCorp**.

Durante meu turno, o SIEM gerou um alerta de malware detectado pelo antivírus corporativo em uma estação de trabalho do setor financeiro.

O alerta indicava:

- detecção de trojan
- execução a partir da pasta Downloads
- tentativa de quarentena automática

Meu objetivo era:

- validar a detecção
- entender como o arquivo chegou ao host
- verificar execução do malware
- identificar impacto inicial
- coletar IOC
- escalar corretamente o incidente

Alerta recebido

Alert: Malware Detected

Host: FIN-PC-019

User: l.martins

Severity: High

Threat Name:

Trojan.GenericKD.44192

File:

C:\Users\l.martins\Downloads\invoice_2026.pdf.exe

Action:

Quarantined

Time:

2026-05-12 11:08:14

Primeira análise

Assim que visualizei o alerta, alguns pontos chamaram minha atenção:

Evidência	Motivo
extensão dupla	técnica comum em phishing
pasta Downloads	origem provável de usuário
nome invoice	engenharia social financeira
trojan detectado	possível comprometimento

Minha hipótese inicial foi:

- possível malware entregue por phishing

Investigando no Splunk

Comecei pesquisando eventos relacionados ao host.

Pesquisa inicial no Splunk

index=windows host="FIN-PC-019"
invoice_2026.pdf.exe

Resultado:

EventCode=4688

NewProcessName:
C:\Users\l.martins\Downloads\invoice_2026.pdf.exe

Investigando origem do arquivo

Meu próximo passo foi descobrir:

- como o arquivo chegou na máquina

Pesquisa Splunk — download do arquivo

index=proxy host="FIN-PC-019"
invoice_2026.pdf.exe

Resultado:

URL:
hxxps://payroll-checker[.]com/invoice_2026.pdf.exe

Category:
Newly Registered Domain

Investigando o domínio

Nesse momento comecei a suspeitar fortemente de phishing.

Alguns indicadores:

- domínio recém-criado
- nome tentando parecer legítimo
- arquivo executável disfarçado

Investigando no KQL

Se eu estivesse usando o Microsoft Sentinel faria isso:

Pesquisa KQL — execução do malware

```
DeviceProcessEvents  
| where DeviceName == "FIN-PC-019"  
| where ProcessCommandLine contains "invoice_2026.pdf.exe"  
| project Timestamp,  
  FileName,  
  ProcessCommandLine,  
  InitiatingProcessAccountName
```

Resultado:

FileName:
invoice_2026.pdf.exe

User:
I.martins

Investigando conexões externas

Meu próximo objetivo foi descobrir:

- o malware tentou comunicação externa?

Pesquisa KQL — conexões de rede

```
DeviceNetworkEvents  
| where DeviceName == "FIN-PC-019"  
| where InitiatingProcessFileName  
== "invoice_2026.pdf.exe"
```

Resultado encontrado:

RemoteIP: 45.77.188.92
RemoteUrl: secure-update-check[.]com
Port: 443

A severidade aumentou

Nesse momento percebi que:

- o malware realmente executou
- houve comunicação externa
- existia possibilidade de C2

Investigando persistência

Depois disso procurei:

- chaves Run
- tarefas agendadas
- serviços criados

Pesquisa Splunk — persistência

```
index=windows host="FIN-PC-019"  
("Run\\" OR "schtasks" OR "Startup")
```

Resultado:

Registry Run Key Added

Key:

HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Value:
UpdaterCheck

Investigando e-mail relacionado

Quis confirmar possível phishing.

Pesquisa Splunk — e-mail recebido

index=email l.martins
invoice

Resultado:

Subject:
Pending Invoice Payment

Sender:
finance@payroll-checker.com

Conclusão da investigação

Nesse momento eu já possuía evidências claras de comprometimento:

Evidência	Resultado
execução do malware	confirmada
comunicação externa	confirmada
persistência	identificada
phishing	provável origem

IOC identificados

Arquivo malicioso

invoice_2026.pdf.exe

Domínio de download

payroll-checker.com

Domínio C2

secure-update-check.com

IP remoto

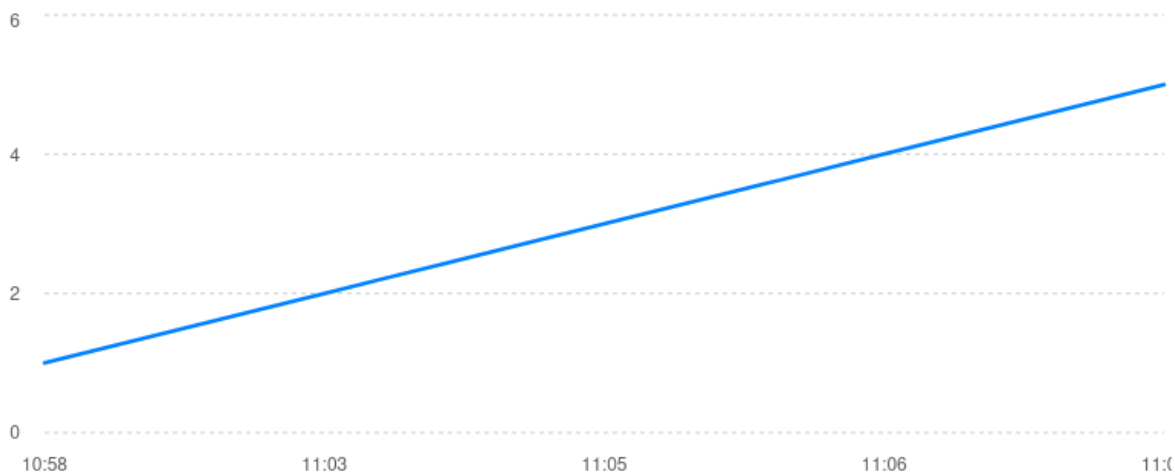
45.77.188.92

Minhas ações como SOC Analyst N1

Após validar o comprometimento:

- Escalei imediatamente para N2
- Solicitei isolamento da máquina
- Registrei IOC encontrados
- Solicitei bloqueio dos domínios/IP
- Recomendei reset de credenciais do usuário
- Documentei timeline do incidente

Timeline do incidente



Eventos identificados durante a investigação do malware.

Legenda:

- 1 = e-mail recebido
- 2 = download do arquivo
- 3 = execução do malware
- 4 = comunicação externa
- 5 = persistência criada

Relatório SOC N1

Foi identificado malware do tipo trojan na estação FIN-PC-019.

Durante a investigação foram observados:

- download de executável suspeito
- execução do payload
- comunicação externa
- persistência via chave Run
- possível origem por phishing

IOC identificados:

- Arquivo: invoice_2026.pdf.exe
- IP: 45.77.188.92
- Domínios:
payroll-checker.com
secure-update-check.com

Incidente escalado para equipe N2 e host encaminhado para contenção.

DeviceRegistryEvents

| where RegistryKey contains "Run"

O que aprendi nesse laboratório

- Como investigar detecção de malware
- Como identificar phishing
- Como correlacionar logs
- Como investigar persistência
- Como analisar comunicação externa
- Como coletar IOC
- Como utilizar Splunk e KQL



Autor: Paulo Cesar
Formado em Segurança da informação
[linkedin.com/in/paulo-cesar-security](https://www.linkedin.com/in/paulo-cesar-security)